NIST AI RMF · FOR CISOS

The questions I'd ask for each function of the NIST AI RMF

Most programs finish GOVERN and MAP on paper. MEASURE and MANAGE are where they stall. Here's how to find out where yours stands.

Save this for your next AI intake or board review

GOVERN | MAP | MEASURE | MANAGE

Greg Crowley · CISO · Author, Secure AI Enablement

THE SHAPE OF IT

Four functions. One of them runs through the others.

GOVERN

Culture, ownership, policy and accountability. Cross-cutting.

MAP

Context: what the system is, where it runs, what it can affect.

MEASURE

Test, benchmark and monitor the risks you mapped.

MANAGE

Act on the risks: prioritize, respond, recover, and stop a system when you need to.

> "Governance is designed to be a cross-cutting function to inform and be infused throughout the other three functions."
>
> NIST AI 100-1, Fig. 5

FUNCTION 1

GOVERN

> GOVERN "cultivates and implements a culture of risk management within organizations designing, developing, deploying, evaluating, or acquiring AI systems."
>
> NIST AI 100-1, 5.1

ASK YOUR TEAM

1. Who is the accountable owner of each AI system, by name?
2. Who can accept residual risk, and at what risk level does that move up to executives?
3. What forces a re-review: a model update, new data, new tools?

FUNCTION 2

MAP

> "AI actors in charge of one part of the process often do not have full visibility or control over other parts and their associated contexts."
>
> NIST AI 100-1, 5.2

ASK YOUR TEAM

1. What data and tools can this system reach?
2. Which actions can it take without a human approving them?
3. What don't we know about it yet, and who is finding out by when?

FUNCTION 3

MEASURE

> "AI systems should be tested before their deployment and regularly while in operation."
>
> NIST AI 100-1, 5.3

ASK YOUR TEAM

1. What does normal behavior look like for this system, in numbers?
2. If it started drifting today, how many days until we'd notice?
3. Is our testing evidence we can rerun, or a one-time sign-off?

FUNCTION 4

MANAGE

> MANAGE 2.4: mechanisms are in place "to supersede, disengage, or deactivate AI systems that demonstrate performance or outcomes inconsistent with intended use."
>
> NIST AI 100-1, Table 4

ASK YOUR TEAM

1. Who can stop this system, and how many minutes does it take?
2. When did we last test the stop?
3. Does our incident response plan cover an AI system acting outside its purpose?

WHERE PROGRAMS STALL

Documents can satisfy the first half. The second half needs runtime.

GOVERN + MAP

- Owners
- Policies
- Inventory
- Risk register

MEASURE + MANAGE

- Behavior baselines
- Drift detection
- Controls in the execution path
- A tested stop

If your evidence for MANAGE 2.4 is a policy document, you have a gap.

BEFORE YOU USE THIS

> "Actions do not constitute a checklist, nor are they necessarily an ordered set of steps."
>
> NIST AI 100-1, 5

Use the questions to find gaps. The full framework is free from NIST: search "NIST AI 100-1". NIST's online AI RMF Playbook adds suggested actions for each subcategory.

Which function would your program struggle to show evidence for?